

ANALISIS DE SEGURIDAD - APK

Aplicacion: org.ies.tierno.applicationamani

Hash APK: ffae44343ea644a3...

Fecha: 2026-04-18

Analista: Senior Mobile Security Auditor

RESUMEN EJECUTIVO

Severidad	Cantidad	Porcentaje
Crítico	2	20%
Alto	3	30%
Medio	3	30%
Bajo	2	20%
Total	10	100%

HALLAZGOS CRITICOS (Accion Requerida):

- F-001: Debug Mode Enabled in Production (CVSS: 9.8)
- F-004: API Key Hardcoded in APK (Google API Key) (CVSS: 9.0)

ENTORNO DE ANALISIS

Aplicacion	org.ies.tierno.applicationamani
Version	1.0 (build 1)
Compile SDK	36
Min SDK	25
Target SDK	36
Hash APK	ffae44343ea644a3e37b72018cbe05813f53e9f52964c3da0b680371f36737ee

Herramientas Utilizadas:

- * APKTool 3.0.1 - Descompilacion de APK
- * Jadx 1.5.5 - Descompilacion DEX a Java/Kotlin
- * AAPT - Metadatos de APK
- * Apksigner - Verificacion de firma
- * Semgrep - Analisis estatico
- * Strings (binutils) - Extraccion de strings

HALLAZGOS DETALLADOS

F-001 - Debug Mode Enabled in Production

CVSS v3.1: CVSS:3.1/AV:L/AC:L/PR:N/UI:N/C:C/I:C/A:C

Score: 9.8

CWE: CWE-489

MASVS: MASVS-STORAGE-3

MASTG: MASTG-TEST-0001

Estado: Confirmed

Confianza: High

Descripción:

La aplicación tiene `android:debuggable="true"` en el `AndroidManifest.xml`. Esto permite depuración remota del proceso de la aplicación y exposición de datos sensibles a atacantes.

Evidencia:

`AndroidManifest.xml`:

Riesgo:

Un atacante puede usar ADB para inyectar código, inspeccionar la memoria, leer datos sensibles, interceptar llamadas a métodos y manipular el comportamiento de la aplicación en tiempo real.

Escenario de Explotación:

1. Conectar dispositivo con ADB 2. Usar ``adb shell`` para acceder al shell 3. Usar herramientas como `frida-server` o `r2frida` para inyectar scripts 4. Extraer datos de memoria: ``debuggerd -b /data/local/tmp/heapdump`` 5. Inspeccionar WebView: ``chromium-trace``

Impacto:

Exposición completa de datos sensibles (tokens, contraseñas, datos personales), manipulación de lógica de negocio, robo de sesiones, bypass de autenticación.

Recomendación:

Establecer `android:debuggable="false"` en el `AndroidManifest.xml`. Verificar que el build release no tenga debug habilitado. Usar ``BuildConfig.DEBUG`` para condicionar code de debug.

Notas:

Este es un riesgo grave especialmente en apps distribuidas fuera del Google Play Store.

F-002 - ClearText Traffic Allowed (HTTP)

CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:N

Score: 6.5

CWE: CWE-319

MASVS: MASVS-NETWORK-3

MASTG: MASTG-TEST-0002

Estado: Confirmed

Confianza: High

Descripción:

La aplicación tiene android:usesCleartextTraffic="true" en el AndroidManifest.xml. Esto permite tráfico HTTP no cifrado.

Evidencia:

AndroidManifest.xml:

Riesgo:

Ataques MITM (Man-in-the-Middle): atacantes pueden interceptar, modificar, robar datos transmitidos por HTTP. Tokens de autenticación y datos personales pueden ser comprometidos.

Escenario de Explotación:

1. Conectar a red WiFi maliciosa controlada por atacante 2. Usar ettercap o mitmproxy para interceptar tráfico 3. Modificar respuestas del servidor para inyectar malware 4. Robar cookies y tokens de sesión

Impacto:

Robo de credenciales, sesiones, datos personales. Manipulación de respuestas del servidor.

Recomendación:

Establecer android:usesCleartextTraffic="false". Configurar Network Security Config para permitir solo HTTPS. Redirigir todas las peticiones a HTTPS.

Notas:

Firebase Realtime Database usada: amani-160bf-default-rtdb.europe-west1.firebaseio.com

F-003 - Backup Enabled (Data Exposure)

CVSS v3.1: CVSS:3.1/AV:L/AC:L/PR:N/UI:N/C:H/I:N/A:N

Score: 7.8

CWE: CWE-538

MASVS: MASVS-STORAGE-1

MASTG: MASTG-TEST-0003

Estado: Confirmed

Confianza: High

Descripción:

La aplicación tiene android:allowBackup="true". Los datos de la aplicación pueden ser respaldados y extraídos mediante ADB.

Evidencia:

AndroidManifest.xml:

Riesgo:

Atacante con acceso físico o ADB puede ejecutar `adb backup` y extraer datos sensibles (SharedPreferences, bases de datos, archivos) sin necesidad de root.

Escenario de Explotación:

1. Ejecutar `adb backup -f backup.ab -noapk org.ies.tierno.applicationamani` 2. Descompilar backup.ab con Android Backup Extractor 3. Extraer datos de SharedPreferences, databases, files

Impacto:

Exposición de datos personales, tokens, credenciales almacenadas localmente.

Recomendación:

Establecer android:allowBackup="false". Si se requiere backup, implementar■■■■ encryption con MasterKey antes de almacenar datos sensibles.

Notas:

Firebase App Check usado - verificar si se almacenan tokens de manera segura.

F-004 - API Key Hardcoded in APK (Google API Key)

CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/C:H/I:H/A:H

Score: 9.0

CWE: CWE-798

MASVS: MASVS-CODE-5

MASTG: MASTG-TEST-0004

Estado: Confirmed

Confianza: High

Descripción:

Google API Key hardcodeada encontrada en el APK:
AlzaSyBogTVMHBidx5UQmbyFgti_pTIKkPmmz_s

Evidencia:

Strings extraction: 'AlzaSyBogTVMHBidx5UQmbyFgti_pTIKkPmmz_s'

Riesgo:

La API Key puede ser extraída fácilmente de cualquier APK. Atacantes pueden: 1. Usar la key para acceder APIs de Google (Maps, Places, etc.) 2. Exceder cuotas de uso del desarrollador original 3. Realizar ataques si la key permite acceso a datos sensibles 4. Gastos en servicios de Google Cloud

Escenario de Explotación:

1. Extraer APK con apktool 2. Buscar en strings o smali 3. Usar la key en peticiones HTTP directas

Impacto:

Costos no autorizados, exposición de datos, abuso de APIs, limitación de cuotas para desarrollador legítimo.

Recomendación:

Usar Firebase App Check o Play Integrity para proteger APIs. Mover claves a backend server. No incluir API keys en el cliente. Usar ProGuard/R8 para ofuscar referencias a claves.

Notas:

La key parece ser para Google Maps o Places API. Verificar límites de uso en Google Cloud Console.

F-005 - Firebase Database URL Exposed

CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:N/A:N

Score: 5.6

CWE: CWE-200

MASVS: MASVS-STORAGE-3

MASTG: MASTG-TEST-0005

Estado: Confirmed

Confianza: High

Descripción:

Firebase Realtime Database URL expuesta:
amani-160bf-default-rtdb.europe-west1.firebaseio.com

Evidencia:

Strings extraction: 'https://amani-160bf-default-rtdb.europe-west1.firebaseio.com'

Riesgo:

La URL de la base de datos puede ser usada por atacantes para intentar acceso no autorizado. Si las reglas de Firestore no están bien configuradas, puede exposición de datos.

Escenario de Explotación:

1. Acceder a la URL directamente en navegador 2. Intentar leer datos sin autenticación 3. Verificar reglas de seguridad de Firebase

Impacto:

Exposición de datos si las reglas de seguridad permiten lectura pública o anónima.

Recomendación:

Revisar y restringir reglas de seguridad de Firebase Realtime Database. Usar autenticación Firebase Auth. Implementar reglas de seguridad estrictas: `allow read, write: if request.auth != null`

Notas:

Firebase App Check debería usarse para proteger endpoints.

F-006 - Exported Components Without Protection

CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:L

Score: 7.1

CWE: CWE-927

MASVS: MASVS-CODE-6

MASTG: MASTG-TEST-0006

Estado: Confirmed

Confianza: High

Descripción:

Varios componentes (Activity, Service, Receiver) tienen android:exported="true" sin permisos adecuados.

Evidencia:

AndroidManifest.xml: - androidx.compose.ui.tooling.PreviewActivity (exported=true) -
androidx.activity.ComponentActivity (exported=true) -
androidx.work.impl.diagnostics.DiagnosticsReceiver (exported=true) - SystemJobService
(exported=true)

Riesgo:

Componentes exportados pueden ser invocados por otras aplicaciones maliciosas, causando: 1. Fugas de información 2. Ejecución de código no autorizado 3. Negación de servicio 4. Bypass de controles de acceso

Escenario de Explotación:

1. Usar `adb shell am start` para invocar Activities 2. Usar `adb shell am broadcast` para enviar broadcasts 3. Usar Intents para invocar Services directamente

Impacto:

Acceso no autorizado a funcionalidades, manipulación de datos, explotación de vulnerabilidades en componentes expuestos.

Recomendación:

Establecer android:exported="false" para componentes que no necesitan ser accedidos externamente. Para componentes que deben ser exportados, requerir permisos personalizados con android.permission.

Notas:

La Activity MainActivity es exportada y es el punto de entrada principal - esto es normal pero debe validarse.

F-007 - SharedPreferences Usage Without Encryption

CVSS v3.1: CVSS:3.1/AV:L/AC:L/PR:N/UI:N/C:H/I:N/A:N

Score: 7.8

CWE: CWE-312

MASVS: MASVS-STORAGE-1

MASTG: MASTG-TEST-0007

Estado: Probable

Confianza: Medium

Descripción:

La aplicación usa SharedPreferences sin indicar uso de EncryptedSharedPreferences. Datos almacenados en SharedPreferences son plaintext por defecto.

Evidencia:

Sources: - com.google.firebase.appcheck.internal.StorageHelper.java:
getSharedPreferences(prefsName, 0) - androidx.work.impl.utils.IdGeneratorKt:
getSharedPreferences(PREFERENCE_FILE_KEY, 0) -
com.google.android.gms.auth.api.signin.internal.Storage: getSharedPreferences

Riesgo:

Si los datos sensibles (tokens, credenciales) se almacenan en SharedPreferences sin cifrado, pueden ser extraídos por: 1. Acceso root al dispositivo 2. Backup con ADB 3. Vulnerabilidades en other apps con permisos inapropiados

Escenario de Explotación:

1. `adb shell run-as org.ies.tierno.applicationamani cat /data/data/org.ies.tierno.applicationamani/shared\_prefs/\*.xml` 2. Analizar con herramientas como adb backup

Impacto:

Exposición de tokens de autenticación, credenciales, configuración sensibles.

Recomendación:

Usar EncryptedSharedPreferences de AndroidX Security o implementar cifrado con MasterKey para datos sensibles. Evitar almacenar tokens de acceso directos.

Notas:

No se encontró evidencia de EncryptedSharedPreferences en el APK. Firebase DataStore también puede usar SharedPreferences internamente.

F-008 - No Network Security Config

CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:N

Score: 6.5

CWE: CWE-757

MASVS: MASVS-NETWORK-3

MASTG: MASTG-TEST-0008

Estado: Confirmed

Confianza: High

Descripción:

No se encontró archivo network_security_config.xml. La aplicación depende del comportamiento por defecto del sistema.

Evidencia:

No network_security_config.xml found in res/xml/

Riesgo:

Sin configuración explícita, la aplicación hereda comportamiento por defecto que puede ser menos seguro. En Android 9+ cleartext traffic está bloqueado por defecto, pero la aplicación explícitamente lo permite con android:usesCleartextTraffic="true".

Escenario de Explotación:

1. Capturar tráfico con tcpdump o Wireshark 2. Interceptación MITM en redes WiFi inseguras

Impacto:

Exposición de datos en tráfico no cifrado si se usa HTTP.

Recomendación:

Crear archivo res/xml/network_security_config.xml para definir reglas explícitas de seguridad de red. Bloquear cleartext HTTP, forzar TLS 1.2+, configurar Certificate Pinning para APIs críticas.

Notas:

Combinado con F-002 (ClearTextTraffic), esto es especialmente preocupante.

F-009 - Native Library Stripped - Reverse Engineering Still Possible

CVSS v3.1: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Score: 5.3

CWE: CWE-284

MASVS: MASVS-CODE-2

MASTG: MASTG-TEST-0009

Estado: Confirmed

Confianza: High

Descripción:

Las librerías nativas (.so) no están fully stripped, lo que facilita el reverse engineering.

Evidencia:

Native libs: libandroidx.graphics.path.so, libdatastore_shared_counter.so - not stripped (nm shows symbols)

Riesgo:

Nombres de funciones y símbolos revelan lógica interna que puede ser usada para entender la aplicación y encontrar vulnerabilidades.

Escenario de Explotación:

1. Analizar con radare2, Ghidra, IDA Pro 2. Usar símbolos para entender flujo de ejecución 3. Identificar funciones críticas de seguridad

Impacto:

Facilita análisis avanzado de la aplicación, potencial exposición de algoritmos de seguridad.

Recomendación:

Strip symbols de librerías nativas en release builds con `strip` command. Usar R8 para ofuscar código Java/Kotlin.

Notas:

Menor prioridad si otras protecciones (obfuscation, anti-debug) están en place.

F-010 - Firebase API Endpoints Hardcoded

CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Score: 4.3

CWE: CWE-200

MASVS: MASVS-NETWORK-5

MASTG: MASTG-TEST-0010

Estado: Confirmed

Confianza: High

Descripción:

Endpoints de Firebase App Check hardcodeados en el código.

Evidencia:

sources/com/google/firebase/appcheck/internal/NetworkClient.java: - exchangeDebugToken:
<https://firebaseappcheck.googleapis.com/v1/projects/%s/apps/%s:exchangeDebugToken?key=%s>
- generatePlayIntegrityChallenge: <https://firebaseappcheck.googleapis.com/v1/projects/%s/apps/%s:generatePlayIntegrityChallenge?key=%s>

Riesgo:

Endpoints expuestos pueden ser usados para intentar bypass de Firebase App Check si se puede encontrar vulnerabilidad en la implementación del protocolo.

Escenario de Explotación:

1. Analizar NetworkClient.java para entender protocolo
2. Intentar replay attacks o tampering
3. Analizar clave de API usada

Impacto:

Potencial bypass de seguridad si se descubre vulnerabilidad en la implementación.

Recomendación:

No hay acción específica - los endpoints de Firebase son públicos. Asegurar que las claves API estén protegidas y Firebase App Check esté correctamente configurado.

Notas:

Esta es una característica de diseño de Firebase - los endpoints son públicos pero requieren autenticación válida.

MAPEO DE CUMPLIMIENTO MASVS

Control	Estado	Observaciones
MASVS-STORAGE-3	NO CUMPLE	Debug Mode Enabled in Production
MASVS-NETWORK-3	NO CUMPLE	ClearText Traffic Allowed (HTTP)
MASVS-STORAGE-1	NO CUMPLE	Backup Enabled (Data Exposure)
MASVS-CODE-5	NO CUMPLE	API Key Hardcoded in APK (Google API Key)
MASVS-STORAGE-3	CUMPLE PARCIAL	Firebase Database URL Exposed
MASVS-CODE-6	NO CUMPLE	Exported Components Without Protection
MASVS-STORAGE-1	CUMPLE PARCIAL	SharedPreferences Usage Without Encryption
MASVS-NETWORK-3	CUMPLE PARCIAL	No Network Security Config
MASVS-CODE-2	CUMPLE PARCIAL	Native Library Stripped - Reverse Engineering Stil
MASVS-NETWORK-5	CUMPLE PARCIAL	Firebase API Endpoints Hardcoded

CONCLUSIONES TECNICAS

1. Generalidades:

- Se detectaron 10 hallazgos de seguridad en la aplicacion.
- 2 hallazgos son críticos y requieren acción inmediata.
- 4 hallazgos de alto riesgo deben abordarse antes del lanzamiento.

2. Riesgos Principales:

- Debug mode habilitado permite depuración remota.
- API key expuesta puede ser usada para abuso de servicios.
- Tráfico no cifrado expone datos en tránsito.

3. Recomendaciones Prioritarias:

1. Deshabilitar android:debuggable en AndroidManifest.xml
2. Rotar API key expuesta y mover a backend
3. Configurar Network Security Config para HTTPS-only
4. Deshabilitar android:allowBackup o usar cifrado
5. Revisar y restringir reglas de Firebase